

Relatorio de Analise de Vulnerabilidades

Sistema Integrado de Atendimento e Execucao de Servicos — Oficina Mecanica (MVP back-end)

Tech Challenge FIAP / Pos Tech — Fase 1 — Data: junho/2026 — Responsavel: [preencher]

1. Objetivo

Identificar vulnerabilidades em dependencias (SCA) e no codigo/configuracao do back-end, e registrar o resultado do scan conforme exigido na entrega da Fase 1.

2. Metodologia e ferramentas

Camada	Ferramenta	Comando
Dependencias (.NET)	dotnet list package	dotnet list package --vulnerable --include-transitive
Deps/segedros/config	Trivy (filesystem)	trivy fs --scanners vuln,secret,misconfig .
Imagem Docker	Trivy (image)	docker build -t oficina-api . && trivy image oficina-api
Pacotes desatualizados	dotnet	dotnet list package --outdated

O script scripts/security-scan.sh executa os scans e orienta onde colar a saida. Requer o .NET 8 SDK (e Trivy, opcional).

3. Analise das dependencias diretas

Pacote	Versao	Funcao	Status conhecido
Microsoft.EntityFrameworkCore	8.0.6	ORM	Sem advisory na linha 8.0.6
Npgsql.EntityFrameworkCore.PostgreSQL	8.0.4	Provider PostgreSQL	Nao afetado (CVE-2024-32655)
Microsoft.AspNetCore.Authentication.JwtBearer	8.0.6	Validacao JWT	Sem advisory na 8.0.6
System.IdentityModel.Tokens.Jwt	8.0.1	Emissao de JWT	Nao afetado (CVE-2024-21319)
Swashbuckle.AspNetCore	6.6.2	Swagger/OpenAPI	Sem advisory conhecido
FluentValidation	11.9.2	Validacao	Sem advisory conhecido

Dependencias transitivas (ex.: System.Text.Json, Microsoft.IdentityModel.*) sao puxadas pelo runtime .NET 8 e pelos pacotes acima; confirmar com --include-transitive. Manter o SDK atualizado garante os patches dessas transitivas.

4. CVEs verificados explicitamente

CVE	Descricao	Versao usada	Situacao
CVE-2024-32655	Npgsql — SQL Injection via overflow do tamanho de mensagem do protocolo (afeta <= 8.0.2)	8.0.4	Nao afetado (corrigido em 8.0.3)
CVE-2024-21319	System.IdentityModel.Tokens.Jwt — DoS por JWE com alta taxa de compressao	8.0.1	Nao afetado (corrigido em 7.1.2)

Nenhuma vulnerabilidade de severidade alta/critica foi identificada nas versoes fixadas com base nessa verificacao. A confirmacao definitiva vem da saida do scan (secao 6).

5. Revisão de segurança do código e configuração

Pontos positivos implementados

- Acesso a dados sem SQL dinâmico: EF Core/LINQ com parâmetros — mitiga SQL Injection.
- Senhas com PBKDF2 (SHA-256, 100.000 iterações, salt aleatório) e comparação em tempo constante; nunca em texto puro.
- JWT Bearer com validação de issuer, audience, assinatura e expiração (ClockSkew = 0); [Authorize] nas rotas administrativas.
- Validação de CPF/CNPJ (dígitos verificadores) e placa (antiga e Mercosul) em Value Objects + FluentValidation nas bordas.
- Middleware central de erros: mensagens padronizadas, sem expor stack trace; exceções não tratadas logadas e respondem 500 genérico.

Riscos residuais e recomendações (hardening)

Item	Risco	Recomendação
Jwt:SecretKey no appsettings	Segredo em repositório	Injetar via variável de ambiente/secret manager; trocar a chave default.
Usuário admin seed (admin/admin123)	Credencial fraca conhecida	Trocar/remover após o primeiro acesso; não usar em produção.
TLS/HTTPS	Traáfego em claro	Terminar TLS no proxy; habilitar HSTS em produção.
Brute force no login	Tentativas ilimitadas	Adicionar rate limiting/lockout no endpoint de login.
CORS	Origem ampla	Restringir origens permitidas conforme o front.
Container	Executa como root	Opcional: usar usuário não-root na imagem final.

6. Resultado do scan (colar saída)

```
# dotnet list package --vulnerable --include-transitive  
[colar aqui]  
  
# trivy fs --scanners vuln,secret,misconfig .  
[colar aqui]
```

7. Conclusão

Com as versões de pacotes fixadas e a verificação dos CVEs aplicáveis, não foram identificadas vulnerabilidades de severidade alta/crítica nas dependências, e o código adota práticas de segurança adequadas a um MVP (hash de senha forte, JWT validado, acesso a dados parametrizado, validação de entrada e tratamento de erros sem vazamento). As recomendações de hardening da seção 5 devem ser aplicadas antes de um ambiente produtivo. A saída dos scans (seção 6) complementa este relatório com os resultados ao vivo no momento da entrega.

Fontes

CVE-2024-32655 — Npgsql SQL Injection: <https://github.com/advisories/GHSA-x9vc-6hfv-hg8c>
CVE-2024-21319 — System.IdentityModel.Tokens.Jwt DoS:
<https://security.snyk.io/vuln/SNYK-DOTNET-SYSTEMIDENTITYMODELTOKENSJWT-6148655>

Gerado em 21/06/2026.